

NajmTech Solutions LLC

Information & Cyber Security Policy

Version: 3.1 | Classification: Confidential | Date: 2024-06-01

Document Owner	CISO
Approved By	CEO
Review Cycle	Annual
Applies To	All employees, contractors, and subsidiaries
Regulatory Reference	NCA ECC 1:2018, SAMA CSF v1.0

1. Introduction

NajmTech Solutions LLC is a technology and payment services company regulated under both the National Cybersecurity Authority (NCA) and Saudi Arabian Monetary Authority (SAMA) frameworks. This policy defines the minimum cybersecurity controls required across all business units.

2. Identity and Access Management

2.1 Authentication Policy

The following authentication standards apply:

- All user accounts require a password of minimum 7 characters.
- Passwords must be changed every 120 days.
- MFA is required only for system administrators.
- Shared accounts are permitted for common services such as printers and test environments.

“ECC Control 3-3-4 and SAMA CSF Section 3.3.4 require minimum password length of 8 characters. 7 characters is non-compliant.

“SAMA CSF requires password expiry of maximum 90 days. 120-day expiry is non-compliant.

“SAMA CSF Section 3.3.5 requires MFA for all remote access, not only administrators.

“ECC Control 3-3-2 prohibits shared accounts. All accounts must be individual and traceable.

2.2 Privileged Access

Privileged users are granted permanent administrative access upon role assignment. Privileged access reviews are done every 18 months.

“ECC Control 3-3-3 requires privileged access to follow least privilege principles with time-limited sessions. Permanent admin access is prohibited.

“SAMA CSF requires privileged account reviews at least quarterly, not every 18 months.

3. Cryptography and Data Protection

3.1 Encryption Policy

Data classification and encryption:

- Public data: No encryption required.
- Internal data: Encrypted using RC4 with 128-bit keys.
- Confidential data: Encrypted using AES-128.
- Encryption keys are rotated every 5 years.

RC4 is a broken stream cipher prohibited by NIST and NCA ECC. AES-256 must be used for all sensitive data encryption.

AES-128 is insufficient for confidential data. NCA ECC Control 3-3-8 and SAMA CSF require AES-256 for confidential and sensitive information.

Key rotation every 5 years is excessive. Industry best practice and SAMA CSF require annual or more frequent key rotation for sensitive systems.

3.2 Public Key Infrastructure

SSL certificates with SHA-1 signature algorithm are permitted for legacy internal systems. Self-signed certificates are used for development and staging environments accessible externally.

“SHA-1 is deprecated and prohibited. NCA ECC requires SHA-256 minimum for all digital signatures and certificates.

“Self-signed certificates must not be used on externally accessible systems per NCA ECC Control 3-2-6. Valid CA-signed certificates are required.

4. Vulnerability and Patch Management

Vulnerability scans are conducted annually. Critical patches are applied within 90 days. Penetration testing is not currently performed due to budget constraints.

“NCA ECC Control 3-2-3 requires vulnerability assessments at least quarterly, not annually.

“Critical patches must be applied within 30 days per NCA ECC. 90 days is non-compliant.

“NCA ECC Control 3-2-4 requires penetration testing at least annually. Budget constraints are not an acceptable exception.

5. Cloud Security

NajmTech uses public cloud services for storing customer payment data. No formal cloud security assessment has been performed on cloud providers. Data residency requirements have not been verified.

“SAMA CSF Section 3.5 requires formal security assessment of all cloud service providers before use for financial data.

“NCA ECC and SAMA CSF require data residency verification. Customer payment data must comply with Saudi data localization requirements.

6. Supplier and Third-Party Security

Third-party suppliers are provided with network access without formal security agreements. Access is not revoked upon contract termination unless explicitly requested.

“NCA ECC Control 1-5-1 requires formal security agreements with all third parties before granting access.

“Access revocation must be immediate upon contract termination per NCA ECC Control 3-3-1. Manual request processes are non-compliant.

7. Physical Security

The main data center is located in a shared office building. Access is controlled by a standard office key. No CCTV monitoring is in place for the server room.

“NCA ECC Control 2-2-1 requires data centers to have multi-factor physical access controls, not standard keys.

“NCA ECC Control 2-2-2 requires CCTV monitoring of all data center and server room areas.